



NexaPay

Plateforme de Paiement Numérique

Whitepaper Technique
Préparé pour
La Banque de Tunisie

Mai 2026

Glitch Inc — BackendGlitch Division
backendglitch.com | contact@backendglitch.com
nexapay.space | sandbox.nexapay.space

Contents

1	Présentation de NexaPay	3
1.1	URLs Publiques	3
1.2	Architecture	3
2	Sécurité et Protection des Données	4
2.1	Protection des Données Utilisateur	4
2.2	Pourquoi 3 Validateurs (BFT) ?	5
2.3	Flux d'Authentification	5
3	Processus KYC (Know Your Customer)	6
3.1	Vérification d'Identité — Particuliers	6
3.2	Vérification des Commerçants — Devenir Agent	6
3.3	Conformité Réglementaire	7
3.4	En Résumé	7
4	Parcours Utilisateur	8
4.1	Inscription (6 étapes)	8
4.2	Fonctionnalités Utilisateur	8
4.3	Dépôt d'Argent en Agence	8
5	Programme Agent / Commerçant	9
5.1	Devenir Agent	9
5.2	Capacités de l'Agent	9
5.3	Intégration Technique	9
5.3.1	Exemple API	9
6	Blockchain et Traçabilité	10
6.1	Propriétés	10
7	Administration et Supervision	11
7.1	Tableau de Bord Administrateur	11
7.2	Gestion des Utilisateurs	11
7.3	Surveillance des Transactions	11
7.4	Gestion des Agents	11
7.5	Sécurité Administrative	12
8	Pourquoi NexaPay ? — Avantages Concurrentiels	13
8.1	Comparaison avec les E-Wallets Existants	13

8.2	Ce Qui Rend NexaPay Unique	13
9	Contact	14

1 Présentation de NexaPay

NexaPay est une plateforme fintech complète conçue pour le marché tunisien. Elle combine un portefeuille numérique, une passerelle de paiement pour commerçants, et un moteur blockchain propriétaire avec consensus BFT à 3 validateurs.

1.1 URLs Publiques

nexapay.space

Page d'accueil publique

sandbox.nexapay.space

Plateforme principale (dashboard, envois, carte)

auth.nexapay.space

Authentification (login, inscription)

backend.nexapay.space

API Backend

nexapay.space/docs

Documentation API & SDK

1.2 Architecture

- **Frontend** — Next.js 16 avec routage par sous-domaines
- **Backend** — Rust/Axum avec JWT, cookies httpOnly, AES-256-GCM
- **Blockchain** — Chaîne append-only, 3 validateurs BFT, signatures Ed25519
- **Base de données** — PostgreSQL 16 + SQLite + Sled
- **SDK** — @nexapay/node-sdk sur npm

2 Sécurité et Protection des Données

La sécurité est au cœur de l'architecture NexaPay. Chaque composant a été conçu avec les meilleures pratiques de l'industrie financière.

2.1 Protection des Données Utilisateur

Données personnelles :

- Les données sensibles (CIN, numéro de téléphone, email) sont stockées dans PostgreSQL avec accès strictement contrôlé
- Les recherches de comptes ne retournent que les 4 derniers chiffres du téléphone et du CIN — jamais les données complètes
- Toutes les communications entre le navigateur et le serveur passent par HTTPS/TLS 1.3

Données bancaires :

- Les numéros de carte Visa et CVV sont chiffrés avec AES-256-GCM (standard militaire)
- Seuls les 4 derniers chiffres de la carte sont visibles — le numéro complet n'est jamais affiché
- Les clés privées Ed25519 des utilisateurs sont chiffrées avec une clé dérivée de leur PIN personnel via Argon2id
- Chaque utilisateur possède un **salt aléatoire unique** pour le hachage de son PIN — rendant les attaques par dictionnaire impossibles

Sessions et Authentification :

- Double authentification : PIN (6 chiffres) + code OTP envoyé par SMS
- Les sessions utilisent des cookies **httpOnly** (inaccessibles au JavaScript, immunisés contre le vol par XSS)
- Les tokens JWT utilisateur et administrateur sont signés avec des **clés cryptographiques distinctes**
- Les sessions peuvent être révoqués côté serveur à tout moment
- Protection contre les attaques par force brute : rate limiting par adresse IP sur toutes les routes d'authentification

Transactions et Blockchain :

- Chaque transaction est enregistrée dans un registre blockchain immuable (append-only)
- Les signatures Ed25519 garantissent la non-répudiation — aucune transaction ne peut être falsifiée
- Le consensus à 3 validateurs assure qu'aucune entité seule ne peut modifier l'état de la chaîne
- Les webhooks (notifications commerçants) sont signés avec HMAC-SHA256 pour garantir leur authenticité

2.2 Pourquoi 3 Validateurs (BFT) ?

NexaPay utilise un consensus **Byzantine Fault Tolerant** à 3 validateurs. Contrairement aux systèmes centralisés (un seul serveur) ou aux blockchains publiques (lentes et coûteuses) :

- **Aucun point de défaillance unique** — Si un validateur tombe en panne, les deux autres continuent de fonctionner
- **Validation croisée** — Chaque bloc doit être signé par les 3 validateurs avant d'être ajouté à la chaîne
- **Transactions instantanées** — Pas de minage, pas de proof-of-work. Les transferts sont appliqués en moins d'une seconde
- **Coût zéro** — Pas de frais de gas, pas de commission blockchain. Les transferts entre utilisateurs sont gratuits
- **Souveraineté** — L'infrastructure est hébergée sur nos propres serveurs, pas sur un cloud public étranger

2.3 Flux d'Authentification

1. Utilisateur entre téléphone + PIN (6 chiffres)
2. Vérification PIN avec Argon2id (sel aléatoire unique)
3. Envoi OTP 6 chiffres par SMS (Twilio)
4. Vérification OTP en temps constant (résistant aux attaques temporelles)
5. Session établie avec cookie httpOnly + JWT

3 Processus KYC (Know Your Customer)

Note importante : Le module complet de vérification documentaire et KYC est déjà développé et intégré à la plateforme. Il est actuellement **désactivé en mode sandbox/démo** pour fluidifier les tests — les utilisateurs sont auto-vérifiés. **En production, le flux complet ci-dessous sera activé.**

3.1 Vérification d'Identité — Particuliers

1. Soumission des documents

- L'utilisateur photographie le **recto** et le **verso** de sa Carte d'Identité Nationale (CIN)
- Upload sécurisé avec validation de format (PNG, JPG, max 5 Mo) et stockage chiffré AES-256-GCM

2. Extraction automatique par OCR

- Notre module OCR (Reconnaissance Optique de Caractères) scanne les deux faces de la CIN et extrait automatiquement :
 - Nom et prénom complets
 - Numéro CIN
 - Date de naissance et lieu de naissance
 - Date d'émission de la CIN
- Les données extraites sont croisées avec le formulaire d'inscription pour vérifier la cohérence

3. Test de vivacité (Liveness Detection)

- L'utilisateur effectue un **test de vivacité** via la caméra de son téléphone
- Le système vérifie qu'il s'agit d'une personne réelle et vivante (pas une photo imprimée, pas une vidéo)
- Mouvements demandés : clignement des yeux, rotation de la tête, sourire
- Un **score de correspondance faciale** est calculé entre la photo de la CIN et le selfie en direct

4. Vérification croisée et approbation automatique

- Si le score de vivacité dépasse le seuil de confiance requis **ET** que les données CIN correspondent au formulaire
- Le compte est automatiquement marqué `kyc_status = verified`
- **Aucune intervention humaine nécessaire** — le processus est entièrement automatisé
- L'utilisateur peut immédiatement accéder à toutes les fonctionnalités

3.2 Vérification des Commerçants — Devenir Agent

Pour les candidats agents/commerçants, un processus de vérification documentaire similaire est appliqué :

1. Soumission des documents professionnels

- **Patente / Licence commerciale** (PDF) — scan du document officiel
- **Extrait du Registre National des Entreprises (RNE)** (PDF)
- Formulaire avec : nom commercial, type d'activité, matricule fiscal, adresse, volume mensuel estimé

2. Scan et vérification automatique des documents

- Notre algorithme scanne les documents professionnels soumis
- Extraction automatique des informations clés : raison sociale, matricule fiscal, date d'enregistrement, adresse du siège
- Vérification croisée de la cohérence entre la patente et le RNE
- Contrôle de validité : les documents doivent être lisibles, non expirés, et correspondre aux informations du formulaire

3. Scoring de risque automatisé

- Le système attribue un **score de risque** basé sur la qualité des documents, la cohérence des données, et le volume estimé
- Si le score est dans la plage acceptable ET que tous les documents sont valides
- L'agent est **automatiquement approuvé** — création de l'espace entreprise, génération de la clé API
- **Aucune intervention humaine** dans le processus standard

4. Cas litigieux

- Si le score est en dessous du seuil ou si les documents présentent des incohérences
- Le dossier est transmis à un **administrateur humain** pour révision manuelle
- L'administrateur peut approuver, rejeter, ou demander des documents complémentaires

3.3 Conformité Réglementaire

Le processus KYC et de vérification documentaire est conçu pour être conforme avec :

- La réglementation de la Banque Centrale de Tunisie (BCT)
- Les directives LCB-FT (Lutte Contre le Blanchiment et le Financement du Terrorisme)
- La Loi n° 2004-63 sur la protection des données personnelles

3.4 En Résumé

Module	Statut
KYC Particuliers (CIN + OCR + Liveness)	Intégré — Actif en production
Scan Patente / RNE Commerçants	Intégré — Actif en production
Approbation automatique Agent	Intégrée — Actif en production
Revue manuelle (cas litigieux)	Disponible pour les administrateurs
Actuellement désactivés en sandbox — démonstration fluide	

4 Parcours Utilisateur

4.1 Inscription (6 étapes)

1. **Téléphone** — Numéro tunisien (+216 XX XXX XXX)
2. **Informations personnelles** — Nom, prénom, email, date de naissance
3. **Identité** — Numéro CIN et date d'émission
4. **Contrat** — Signature électronique du contrat (Loi n° 2002-50)
5. **PIN** — Code 6 chiffres pour transactions
6. **Activation** — IBAN/RIB tunisien + carte Visa virtuelle + 150 TND offerts

4.2 Fonctionnalités Utilisateur

- **Portefeuille** — Solde TND, IBAN/RIB, carte Visa virtuelle
- **Envoi d'argent** — Transferts instantanés et gratuits entre utilisateurs
- **Virement bancaire** — Vers n'importe quel RIB tunisien
- **Rechargement** — Dépôt espèces en agence bancaire partenaire
- **Païement en ligne** — Checkout NexaPay chez les commerçants
- **Historique** — Transactions on-chain, vérifiables
- **Carte virtuelle** — Achats en ligne, gel/dégel

4.3 Dépôt d'Argent en Agence

1. Le client se rend dans une agence de **La Banque de Tunisie**
2. Il fournit son numéro de téléphone ou son adresse NexaPay
3. L'agent bancaire vérifie l'identité du client
4. Le dépôt en espèces est effectué au guichet
5. L'agent crédite le compte via l'interface administrateur
6. Le solde est mis à jour en temps réel

5 Programme Agent / Commerçant

5.1 Devenir Agent

1. **Candidature** — Formulaire avec nom commercial, type d'activité, matricule fiscal, adresse, volume estimé. Upload licence commerciale (PDF) et extrait RNE (PDF)
2. **Scoring** — Évaluation automatique du risque
3. **Approbation** — Automatique en sandbox, révision manuelle en production
4. **Activation** — Clé API unique, dashboard agent, limite de volume

5.2 Capacités de l'Agent

- **Liens de paiement** — Création de liens/QR codes pour accepter des paiements
- **API REST** — Intégration via API ou SDK Node.js
- **Remboursements** — Partiels ou totaux
- **Solde** — Disponible, volume brut, retraits
- **Retraits** — Transfert solde commercial → portefeuille personnel (on-chain)
- **Webhooks** — Notifications temps réel (succès/échec)
- **Statistiques** — Volume total, taux de succès, transactions du jour
- **Export** — CSV des transactions et clients

5.3 Intégration Technique

Trois modes d'intégration :

1. **No-Code** — Liens/QR codes depuis le dashboard
2. **SDK Node.js** — `npm install @nexapay/node-sdk`
3. **REST API** — Endpoints HTTP avec clé API

5.3.1 Exemple API

```
curl -X POST https://backend.nexapay.space/gateway/v1/intents \
  -H "Content-Type: application/json" \
  -H "X-API-Key: nxp_developer_CLE_API" \
  -d '{"amount":42000,"currency":"TND","description":"Cmd #42",
      "success_webhook_url":"https://maboutique.tn/hook/success"}'
```

6 Blockchain et Traçabilité

- **Consensus BFT** — 3 validateurs, quorum 3/3, signatures Ed25519
- **Registre immuable** — Toutes les transactions on-chain (append-only)
- **12 types de transactions** — Transfer, AccountCreate, EsignAccount, InvoiceAnchor, etc.
- **Ancrage** — Contrats signés et factures hashés et ancrés on-chain
- **Mempool** — 500 transactions max, expiration 5 minutes
- **Persistance** — Sled (blocs) + SQLite (snapshots)

6.1 Propriétés

- **Intégrité** — Chaque bloc référence le hash du bloc précédent
- **Non-répudiation** — Signatures Ed25519 sur transactions utilisateur
- **Auditabilité** — Toute transaction vérifiable indépendamment
- **Résilience** — 3 validateurs redondants

7 Administration et Supervision

NexaPay dispose d'un **panneau d'administration** complet permettant aux administrateurs de la plateforme (Banque de Tunisie) de superviser l'ensemble de l'écosystème en temps réel.

7.1 Tableau de Bord Administrateur

- **Vue d'ensemble** — Nombre total d'utilisateurs, comptes créés aujourd'hui, utilisateurs actifs
- **Volume des transactions** — Montant total transféré, nombre de transactions par jour/semaine/mois
- **Agents** — Nombre d'agents approuvés, en attente, volume traité par agent
- **Solde système** — Vue globale des fonds en circulation

7.2 Gestion des Utilisateurs

- **Liste complète des comptes** — Recherche par nom, téléphone, CIN, ou adresse blockchain
- **Fiche détaillée par utilisateur** — Informations personnelles, solde, historique des transactions, statut KYC, documents soumis
- **Gel de compte** — L'administrateur peut **geler un compte** immédiatement en cas d'activité suspecte. Le compte gelé ne peut plus effectuer de transactions
- **Dégel de compte** — Après vérification manuelle, l'administrateur peut réactiver le compte
- **Journal d'audit** — Toute action administrative est enregistrée avec horodatage, identité de l'administrateur, et raison fournie

7.3 Surveillance des Transactions

- **Historique complet** — Toutes les transactions de la plateforme sont visibles avec : expéditeur, destinataire, montant, horodatage, type, statut
- **Filtrage** — Par date, statut, montant, type de transaction
- **Gel de transaction** — L'administrateur peut **geler une transaction spécifique** pour vérification avant qu'elle ne soit définitivement confirmée
- **Traçabilité blockchain** — Chaque transaction a un hash on-chain vérifiable indépendamment

7.4 Gestion des Agents

- **Candidatures en attente** — Liste des demandes d'agents avec score de risque
- **Approbation / Rejet manuel** — Pour les cas litigieux, l'administrateur peut approuver ou rejeter avec un commentaire
- **Limites de volume** — Ajustement du plafond mensuel par agent
- **Suspension d'agent** — Désactivation temporaire d'un compte agent

7.5 Sécurité Administrative

- **Authentification renforcée** — Login administrateur avec mot de passe + TOTP (code temporaire à 6 chiffres, SHA-256)
- **Clé JWT séparée** — Les tokens administrateur utilisent une clé cryptographique distincte des tokens utilisateur
- **Audit trail** — Chaque action administrative est journalisée (qui, quoi, quand, pourquoi)
- **Protection anti-seed** — La création du premier compte admin nécessite une clé secrète (`NEXAPAY_ADMIN_SEED_KEY`)

8 Pourquoi NexaPay ? — Avantages Concurrentiels

8.1 Comparaison avec les E-Wallets Existants

	E-Wallets Traditionnels	NexaPay
Infrastructure	Serveur centralisé unique	3 validateurs BFT redondants
Vitesse transferts	1–3 jours ouvrés (virement)	Instantané (<1 seconde)
Frais transferts	0.5–2% par transaction	Gratuit entre utilisateurs
Traçabilité	Base de données interne	Blockchain immuable vérifiable
IBAN/RIB	Dépend de la banque partenaire	Généré automatiquement
Carte virtuelle	Parfois disponible	Visa virtuelle incluse
API Commerçants	Limitée ou absente	REST API + SDK npm
Webhooks	Rare	Signés HMAC-SHA256 avec retry
KYC	Manuel (agence)	Automatisé (OCR + liveness)
Contrat électronique	Papier	Signé + ancré blockchain (Loi 2002-50)
Chiffrement	Variable	AES-256-GCM bout en bout

8.2 Ce Qui Rend NexaPay Unique

1. **Blockchain privée à 3 validateurs** — Ni centralisé (risque de panne unique), ni blockchain publique (lente et chère). Un compromis idéal pour la finance : rapidité, sécurité, et coût zéro.
2. **IBAN/RIB tunisien généré automatiquement** — Chaque compte NexaPay reçoit un IBAN et RIB tunisien. Les virements bancaires standards fonctionnent sans adaptation.
3. **Double rôle utilisateur/commerçant** — Un même compte peut être portefeuille personnel ET passerelle de paiement. Pas besoin de deux applications distinctes.
4. **Ancrage blockchain des documents** — Les contrats d'ouverture de compte et les factures sont hashés et enregistrés on-chain. Toute autorité peut vérifier l'authenticité d'un document de manière indépendante.
5. **Conçu pour la Tunisie** — Conforme à la réglementation BCT, formats tunisiens (CIN, RIB 20 chiffres, numéros +216), interface en français, support des dépôts en espèces en agence.
6. **Intégration simple pour les commerçants** — 3 modes : liens de paiement (no-code), SDK npm, ou REST API. Le commerçant choisit selon ses capacités techniques.

9 Contact

Glitch Inc — BackendGlitch Division

Site web backendglitch.com
Email contact@backendglitch.com
GitHub github.com/Samer-Gassouma/NexaPay
SDK npm npmjs.com/package/@nexapay/node-sdk

Landing nexapay.space
Sandbox sandbox.nexapay.space
API Backend backend.nexapay.space
Documentation nexapay.space/docs

Merci de votre attention.

Disponible pour démonstration en direct et questions techniques.

Disponible pour démonstration en direct et questions techniques.

Glitch Inc — BackendGlitch Division © 2026